SİBER GÜVENLİK LABORATUVARI — HAFTA 3 RAPORU

> **Konu:** HTTPS Trafik İncelemesi, TLS Güvenlik Analizi ve Ortadaki Adam (MitM) Simülasyonu
> **Öğrenci Adı Soyadı:** Furkan Akteke
> **Öğrenci Numarası:** 242923100
> **Tarih:** 07.10.2026

1. Giriş ve Amaç

Bu çalışmada, güvenli web iletişiminin temel taşları olan TLS protokolleri, kriptografik şifre paketleri ve Açık Anahtar Altyapısı (PKI) incelenmiştir. Zayıf şifrelenmiş bir sunucu ile güçlendirilmiş bir HTTPS sunucusu karşılaştırılmış; ardından mitmproxy aracı kullanılarak tarayıcı ile sunucu arasındaki şifreli trafiğin hangi koşullarda ele geçirilebileceği test edilmiştir.

2. Görev 1: Zayıf HTTPS Sunucusunun Analizi

Port 8445 üzerinde çalışan sunucu `testssl.sh` aracıyla taranmıştır. Sunucunun güncelliğini yitirmiş ve kriptografik saldırılara açık olan **TLSv1.0** ve **TLSv1.1** protokollerini kabul ettiği saptanmıştır.

Zayif Sunucu Analizi

Görsel 1: Zayıf sunucunun testssl.sh protokol tarama çıktısı (TLS 1.0 ve 1.1 aktif)

3. Görev 2: Güçlü HTTPS Sunucusu ve PKI Doğrulaması

Özel PKI betiği ile yerel bir Kök Sertifika Otoritesi (CA) oluşturulmuş ve `lab.local` adresi için 2048-bit RSA sertifikası üretilmiştir. Sunucu yalnızca modern **TLSv1.3** protokolünü ve AEAD destekli güvenli şifre paketlerini (AES-GCM, ChaCha20) kabul edecek şekilde yapılandırılmıştır.

Guclu Sunucu Analizi

Görsel 2: Güçlü sunucunun testssl.sh taraması (Yalnızca TLSv1.3 ve Öğrenci No içeren Özel CA)

4. Görev 3: MitM Trafik İncelemesi ve Sertifika Güveni

Firefox trafiği yerel vekil sunucuya (127.0.0.1:8080) yönlendirilmiştir. İlk aşamada tarayıcı, araya giren mitmproxy'nin dinamik olarak ürettiği sertifikayı tanıyamadığı için bağlantıyı kesmiş ve **SEC_ERROR_UNKNOWN_ISSUER** uyarısı üretmiştir.



Görsel 3: Firefox'un sahte sertifikayı engelleyerek verdiği MitM güvenlik uyarısı

Kök sertifika (`mitmproxy-ca-cert.pem`) Firefox'un "Authorities" deposuna eklenip güven verildikten sonra güven zinciri tamamlanmış; kilit simgesi temiz hale gelmiş ve terminalde şifresi çözülen GET istekleri açık metin olarak yakalanmıştır.



Görsel 4: Güvenli kilit simgesiyle açılan web sayfası ve mitmproxy açık metin istek akışı

5. Değerlendirme ve Analiz Soruları

6.1. Firefox mitmproxy'nin sunduğu sertifikayı ilk başta neden reddetti ve güvenlik uyarısı verdi?

Cevap: Firefox, HTTPS bağlantılarında sunulan sertifikanın güvenilirliğini kendi güvenilir Kök Sertifika Yetkilileri (Root CA) deposu üzerinden zincirleme olarak denetler. mitmproxy araya girdiğinde hedef alan adı adına anlık sahte bir sertifika üretmiştir. Ancak bu sertifikayı imzalayan mitmproxy CA makamı henüz tarayıcının yerel deposunda kayıtlı olmadığından güven zinciri doğrulanamamış, tarayıcı durumu bir Ortadaki Adam saldırısı kabul ederek bağlantıyı engellemiştir.

6.2. mitmproxy-ca-cert.pem sertifikası Firefox'un "Authorities" deposuna eklendiğinde tarayıcı neden uyarı vermeyi bıraktı?

Cevap: Sertifika "Authorities" sekmesine eklenip web sitelerini tanımlama yetkisi verildiğinde tarayıcı bu makamı resmi ve güvenilir bir Kök Otorite olarak kabul etmiştir. Bu sayede mitmproxy'nin sahte ürettiği sunucu sertifikası artık güvenilen bir CA tarafından onaylanmış göründüğünden sertifika zinciri tamamlanmış, uyarı ortadan kalkmış ve kilit simgesi yeşil/temiz olmuştur.

6.3. Bir saldırganın bu tekniği gerçek hayatta kullanabilmesi için hangi koşullar gereklidir?

Cevap: İki temel koşul gerekir: 1) Saldırganın kurbanın cihazına yönetici haklarıyla erişip kendi Kök CA sertifikasını cihazın güven deposuna yüklemesi (veya sosyal mühendislikle kurbana yükletmesi). 2) Ağ trafiğini kendi vekil sunucusu üzerinden geçirebilecek ağ hakimiyetine (ARP zehirlemesi, DNS sahteciliği veya zararlı Wi-Fi noktası) sahip olması gerekir.

6.4. HSTS ve Certificate Pinning mekanizmaları bu senaryodaki MitM saldırısını nasıl engeller?

Cevap: HSTS, bağlantının sadece HTTPS olmasını zorunlu kılar ve geçersiz sertifika durumunda kullanıcının uyarıyı elle ("Riski Kabul Et") aşmasını engeller. Certificate Pinning ise uygulamanın sunucunun yalnızca belirli bir genel anahtarını/sertifikasını kabul etmesini sağlar; cihaza sahte bir Kök CA yüklenmiş olsa bile parmak izi eşleşmeyeceği için MitM bağlantısı tamamen bloke edilir.

6. Güvenlik Temizliği Onay Beyanı

Bu laboratuvar çalışmasının ardından sistem güvenliğini sağlamak amacıyla şu adımlar eksiksiz uygulanmıştır:

- Firefox vekil sunucu ayarı **"No proxy"** konumuna getirilerek sıfırlanmıştır.
- Firefox *Authorities* deposundaki **mitmproxy** kök sertifikası tamamen silinmiştir.
- `about:config` altındaki `network.proxy.allow_hijacking_localhost` değeri **false** yapılmıştır.
- Python sunucusu ile mitmproxy oturumları kapatılmış, masaüstündeki geçici sertifika dosyası silinmiştir.

Beyan Eden: Furkan Akteke — 07.10.2026

EOF